

Closing the Handoff Gap:

A Reference Architecture for Attenuated Agent Delegation

Verifiable, Monotonic, Cross-Domain Delegation for Multi-Agent Systems

Binod Kumar

Founder & Chief AI Officer, AgentsArchitects.ai

Produced for and with the Frontier Research Lab

<https://frontierresearchlab.org/>

August 2026

Abstract

The agent-to-agent handoff, the moment one AI agent passes work to another, is the seam along which multi-agent systems most often fail. As a companion analysis argues, three structural breakages compound at each hop: identity collapse, where the agent’s identity replaces the human’s; non-attenuation, where privilege never narrows as it is forwarded; and loss of the anchor, where no deployed protocol can prove which human authorized which action three or four hops down a recursive, cross-domain delegation chain. The result is a confused deputy at machine speed. This paper moves from diagnosis to construction. We present the Attenuated Delegation Credential (ADC), a public-key, caveat-based capability whose scope can only ever narrow as it is delegated, and whose chain of signed blocks makes the originating human and every intermediary agent cryptographically verifiable at any depth, across trust domains, without pre-arranged federation. Around it we specify a reference architecture: workload-attested agent identities, an identity-aware enforcement gateway at every boundary, just-in-time attenuated minting, per-action runtime authorization, a tamper-evident transparency log, and depth-bounded delegation with human checkpoints for high-impact actions. We give a formal model and prove five properties: monotone attenuation, intersection-ceiling safety (which reduces the confused-deputy condition to a policy violation the gateway rejects), attribution soundness under existential unforgeability, bounded delegation depth, and contagion containment. We describe a prototype composed from SPIFFE/SPIRE, biscuit-style tokens, Open Policy Agent, and a Merkle transparency log, and give an analytical cost model with illustrative, to-be-validated overhead figures. The architecture satisfies all seven session-trust requirements simultaneously and provably blocks four attack classes, namely injection-driven confused deputy, authority re-delegation contagion, cross-organization token pivots, and identity collapse, that the current composition of OAuth, SPIFFE, or macaroons alone does not.

Keywords: multi-agent systems; delegation chains; holder-side attenuation; capability security; confused deputy; multi-principal attribution; runtime authorization; non-human identity; OAuth Token Exchange; SPIFFE; macaroons.

1 Introduction

Multi-agent architecture has left the demo and entered production. Estimates place a large and growing share of enterprise applications on task-specific agents within the year, with Google’s A2A protocol and the Model Context Protocol (MCP) as the dominant interoperability plumbing [1, 15, 16]. Security attention, however, remains fixed on the individual agent: its prompt, its tools, its guardrails. That framing misses where risk actually accumulates. In a single-agent system the question is what may this agent do. In a multi-agent system a second question arises at every handoff, dozens of times per task, with no human watching: what happens when this agent passes work to another agent [1].

The companion analysis [1] shows that the handoff is the unit of risk and that the human-centric identity stack cannot carry it. OAuth 2.x, OIDC and SAML assume a synchronous human-consent event and single-hop delegation [7, 9]; agents act asynchronously, chain across domains, and re-delegate on their own authority. Three breakages follow. *Identity collapse*: once an agent runs under its own or a shared credential, the target sees a privileged machine, not the human, and the human’s permission ceiling vanishes from view. *Non-attenuation*: OAuth offers no holder-side attenuation, so forwarding the token one already holds (the easy engineering path) spreads full privilege, and effective scope at hop n becomes the union, not the intersection, of every credential touched. *Loss of the anchor*: token exchange mints a fresh, opaque token that carries no record of the prior chain, so by the third or fourth hop no deployed protocol can cryptographically prove which human authorized which specific agent to perform which specific action. Working out which human bears responsibility, what the literature calls multi-principal attribution, remains an open problem [1, 17]. The 2025 Salesloft and Drift incident, in which compromised OAuth tokens were pivoted across more than 700 connected companies, is the single-protocol preview of what autonomous, self-delegating agents generalize [1].

From requirements to a construction. The companion work distills genuine session trust at an agent boundary into seven requirements (Section 2): a verifiable delegation chain, multi-principal attribution, holder-side attenuation, an intersection ceiling, freshness and bounded lifetime, runtime authorization, and revocability with observability [1]. Most production systems satisfy one or two; almost none satisfy all seven. No single building block closes the list: OAuth Token Exchange lacks attenuation and cross-domain anchoring; SPIFFE identifies the workload but not the delegated human authority behind an action; macaroons attenuate but lack mature verification and revocation; MCP and A2A supply plumbing, not guarantees [7, 12, 3]. The near-term answer is to compose them under one model rather than wait for a single protocol.

Contributions. This paper supplies that composition and proves it correct.

- **A formal model of attenuated delegation** (Section 3): principals, capabilities over a scope lattice, a human intersection ceiling, an attenuation operator, and well-formed delegation chains, with precise definitions of monotonicity, intersection safety, and attribution soundness.
- **The Attenuated Delegation Credential (adc)** (Section 4): a public-key, caveat-based capability built from a human-anchored root block and per-hop signed attenuation

blocks. It gives monotonic holder-side attenuation and a chain that is verifiable at arbitrary depth across domains without pre-arranged federation, with proof-of-possession and third-party revocation caveats. We give the MINT, DELEGATE, VERIFYANDAUTHORIZE and REVOKE algorithms.

- **A reference architecture** (Section 5): workload-attested agent identities, an identity-aware enforcement gateway at every boundary, a runtime policy decision point, a Merkle transparency log, a revocation registry, depth bounding, and human checkpoints, mapped explicitly onto existing standards (RFC 8693, Transaction Tokens, G NAP, DPoP, SPIFFE, biscuit, OPA, Certificate Transparency).
- **A security analysis** (Section 6): five theorems, namely monotone attenuation, intersection-ceiling safety, attribution soundness, bounded depth and contagion containment, and a walkthrough showing the architecture provably blocks four attack classes drawn from the companion analysis.
- **A prototype and analytical evaluation** (Section 7): a composition of SPIRE, biscuit-style tokens, OPA and a Merkle log; an $O(n)$ verification cost model; and an explicitly illustrative overhead budget together with a requirement-coverage comparison against OAuth Token Exchange, SPIFFE, macaroons and Transaction Tokens.

2 Background and Threat Model

2.1 System model

A multi-agent system comprises organizations $\mathcal{O}$, humans $\mathcal{H}$, agents $\mathcal{A}$, resources (targets) $\mathcal{S}$, and action verbs $\mathcal{V}$ (for example read, deploy, transfer). A task is initiated by a human $h \in \mathcal{H}$ and executed by a chain of agents $a_0, a_1, \dots, a_n \in \mathcal{A}$, where a_i hands off to a_{i+1} . Each agent may call resources directly or delegate to another agent, possibly in a different trust domain. A privileged action is a pair $(s, v) \in \mathcal{S} \times \mathcal{V}$.

2.2 Trust and adversary model

We assume: (i) a signature scheme that is existentially unforgeable under chosen-message attack (EUF-CMA) and a collision-resistant hash H ; (ii) each agent workload can obtain an attested cryptographic identity (a SPIFFE SVID) bound to a key pair [12]; (iii) each enforcement gateway (Section 5) is a trusted computing base at its own boundary and its signing keys are not disclosed; and (iv) organizational trust roots are discoverable (published verification keys or verifiable credentials), so a verifier can check a foreign domain’s root without prior bilateral federation.

The adversary is powerful within these limits. It may (a) control one or more agents, including via indirect prompt injection that turns a benign agent into a deputy; (b) compromise an intermediary and attempt to widen, replay or forward captured credentials; (c) attempt a cross-organization pivot, reusing trust established for one relationship to reach another; and (d) attempt identity collapse, acting under a shared or service credential to mask the human behind an action. The adversary cannot forge signatures or find hash collisions, and cannot

subvert an honest gateway’s local enforcement. Confidentiality of payloads is out of scope; our target is authority, meaning what a chain is permitted to do and on whose behalf.

2.3 The confused-deputy condition, restated

Following the formalization adopted in the companion analysis [1, 18], let $R_h \subseteq \mathcal{H} \times (\mathcal{S} \times \mathcal{V})$ be the human authorization relation and $R_a \subseteq \mathcal{A} \times (\mathcal{S} \times \mathcal{V})$ the agent authorization relation. A confused-deputy condition arises when an agent a performs (s, v) on behalf of a task initiated by h where

$$(h, (s, v)) \notin R_h \quad \text{yet} \quad (a, (s, v)) \in R_a. \quad (1)$$

The agent’s effective power has collapsed to its own permissions rather than the intersection of its permissions and the human’s. Eliminating condition (1) at every hop, so that effective authority is always $R_a \cap R_h$ and never R_a alone, is the security goal of this paper.

2.4 Requirements

We take the seven session-trust requirements of [1] as design targets and restate them compactly; Table 1 later maps each to a mechanism.

R 1 (Verifiable delegation chain). A holder can prove the full path of authority back to an originating human or organization, not mere possession of a bearer token.

R 2 (Multi-principal attribution). Each action records which human authorized which agent to do what, and the binding survives every later hop.

R 3 (Holder-side attenuation). A holder can mint a strictly weaker capability on its own authority, offline; scope only narrows.

R 4 (Intersection ceiling). Exercised authority is the intersection of policy and the originating human’s ceiling.

R 5 (Freshness and bounded lifetime). Delegated authority is just-in-time, task-scoped and short-lived; no standing, forwardable credentials.

R 6 (Runtime authorization). Authorization is evaluated per action at runtime, not once at the handshake.

R 7 (Revocability and observability). Any link can be cut, and every handoff leaves a tamper-evident record.

3 A Formal Model of Attenuated Delegation

3.1 Scopes, ceilings and capabilities

Let the scope universe be $\mathcal{U} = \mathcal{S} \times \mathcal{V}$, the set of all privileged actions. A scope is a member of a lattice $(\mathcal{L}, \subseteq)$ where each $\sigma \in \mathcal{L}$ denotes a downward-closed set $\llbracket \sigma \rrbracket \subseteq \mathcal{U}$ of permitted actions, with meet $\sqcap$ (interpreted as $\cap$) and a bottom element $\perp$ ($\llbracket \perp \rrbracket = \emptyset$). Concretely a scope is a conjunction of caveats (predicates over $\mathcal{U}$ and context); adding a caveat can only shrink $\llbracket \sigma \rrbracket$.

For a human h , the ceiling $\text{ceil}(h) \in \mathcal{L}$ is the set of actions h may perform directly ($\llbracket \text{ceil}(h) \rrbracket = \{(s, v) : (h, (s, v)) \in R_h\}$). For an agent a and target domain, $\text{pol}(a) \in \mathcal{L}$ is the policy-granted scope.

Definition 1 (Capability). A capability is a tuple $c = \langle \rho, \sigma, d, \tau, \pi \rangle$ where ρ is a root reference identifying the originating human h and issuing organization (and a commitment to $\text{ceil}(h)$ at issue time); $\sigma \in \mathcal{L}$ is the current scope; $d \in \mathbb{N}$ is the remaining delegation depth; τ is an expiry time; and π is a proof-of-possession key binding. Write $\text{scope}(c) = \sigma$, $\text{depth}(c) = d$, $\text{exp}(c) = \tau$.

3.2 Attenuation and chains

Definition 2 (Attenuation). The attenuation of c by (δ, d', τ') , written $c' = c \triangleright (\delta, d', \tau')$, yields $c' = \langle \rho, \sigma \sqcap \delta, \min(d - 1, d'), \min(\tau, \tau'), \pi' \rangle$, defined only when $d \geq 1$. Attenuation preserves the root ρ and never enlarges scope, depth or lifetime.

Definition 3 (Delegation chain). A delegation chain is a sequence $\Gamma = (c_0, c_1, \dots, c_n)$ with a root capability c_0 minted for (h, a_0) and $c_{i+1} = c_i \triangleright (\delta_i, d_i, \tau_i)$ produced by holder a_i delegating to a_{i+1} . Γ is well-formed if every step is a valid attenuation, $\text{depth}(c_i) \geq 1$ for all $i < n$, and all share root ρ .

Definition 4 (Effective authority). The effective authority of a chain is $\text{eff}(\Gamma) = \text{scope}(c_n)$: the scope of the final capability presented at the boundary.

3.3 Security definitions

Definition 5 (Monotonicity). A construction is monotone if for every well-formed chain, $\text{scope}(c_n) \subseteq \text{scope}(c_{n-1}) \subseteq \dots \subseteq \text{scope}(c_0)$.

Definition 6 (Intersection safety). A construction is intersection-safe if for every well-formed chain rooted at h , $\text{eff}(\Gamma) \subseteq \text{ceil}(h)$, that is $\llbracket \text{eff}(\Gamma) \rrbracket \subseteq \{(s, v) : (h, (s, v)) \in R_h\}$.

Definition 7 (Attribution soundness). A construction is attribution-sound if any chain that a gateway accepts for action (s, v) uniquely determines the originating human h and the ordered list of delegating agents $a_0, \dots, a_n$, and no probabilistic polynomial-time adversary can produce an accepted chain whose attribution differs from the parties that actually signed it, except with negligible probability.

4 The Attenuated Delegation Credential

4.1 Construction

An ADC is a list of cryptographic blocks, extending the public-key macaroon and biscuit lineage [3, 4] so that attenuation is offline and verification needs only public keys.

Root block B_0 . Issued by the Delegation Authority of the originating organization. It carries the root reference ρ (human h , organization id, and a signed commitment $H(\text{ceil}(h))$ to the human's ceiling at issue time), the initial scope $\sigma_0 = \text{pol}(a_0) \sqcap \text{ceil}(h)$ (the intersection ceiling, R4), the initial depth $d_{\max}$, expiry τ_0 , the SVID-bound public key of a_0 , and a proof-of-possession public key π_0 . B_0 is signed by the organization root key K_O .

Attenuation block B_{i+1} . When holder a_i delegates to a_{i+1} it appends a block containing added caveats δ_i (narrowing scope), a decremented depth, a not-later expiry, a_{i+1} 's SVID public key, and a fresh PoP key. Crucially, B_{i+1} is signed by a_i 's SVID private key, and includes $H(B_i)$, hash-chaining the block to its predecessor. Because a block can only add caveats, and a verifier evaluates the conjunction of all caveats, scope is monotone by construction (Definition 5).

Cross-domain verification without federation. Each block names the public key (and its SVID trust-domain URI) that signs the next. A verifier in domain D validates a foreign chain by (1) resolving each signer's domain root via published discovery, (2) checking every block signature, and (3) checking the hash-chain links. No prior bilateral federation is needed: trust is transferred by the self-describing public-key chain rooted at a discoverable K_O , not by a shared authorization server [5, 3].

Freshness and possession. Short τ and a required DPoP-style proof-of-possession [8] bind each presentation to the holder's key, so a stolen ADC cannot be replayed by a party lacking the PoP private key (R5).

Revocation. A third-party caveat [3] may require a short-lived discharge ("not revoked as of t ") from a revocation service, checked at the gateway; a published revocation set keyed by block hash provides a coarser fallback (R7).

4.2 Algorithms

Algorithms 1 to 4 give the four operations. MINT establishes the intersection ceiling once; DELEGATE is a purely local, offline attenuation; VERIFYANDAUTHORIZE is the per-action runtime check performed by the gateway; REVOKE publishes a cut.

Algorithm 1: MINT. Issue a root capability (Delegation Authority).

- 1: **input:** human h , first agent a_0 (SVID key pk_0), requested scope σ_r , depth $d_{\max}$, TTL Δ
 - 2: verify h authenticated and consents to task; fetch $\text{ceil}(h)$, $\text{pol}(a_0)$
 - 3: $\sigma_0 \leftarrow \sigma_r \sqcap \text{pol}(a_0) \sqcap \text{ceil}(h)$ $\triangleright$ intersection ceiling (R4)
 - 4: $\rho \leftarrow \langle \text{id}(h), \text{id}(O), H(\text{ceil}(h)) \rangle$
 - 5: $B_0 \leftarrow \langle \rho, \sigma_0, d_{\max}, \tau_0 = \text{now} + \Delta, pk_0, \pi_0 \rangle$
 - 6: **return** ADC $\leftarrow [B_0, \text{Sign}_{K_O}(B_0)]$
-

Algorithm 2: DELEGATE. Attenuate to a successor (holder a_i , offline).

- 1: **input:** current ADC with tail block B_i , successor a_{i+1} (SVID key pk_{i+1}), added caveats δ_i , TTL Δ'
 - 2: **require:** $\text{depth}(B_i) \geq 1$ $\triangleright$ else refuse: depth exhausted (R1)
 - 3: $B_{i+1} \leftarrow \langle \delta_i, \text{depth}(B_i) - 1, \min(\tau_i, \text{now} + \Delta'), pk_{i+1}, \pi_{i+1}, H(B_i) \rangle$
 - 4: ADC' $\leftarrow \text{ADC} \parallel [B_{i+1}, \text{Sign}_{sk_i}(B_{i+1})]$ $\triangleright$ signed by a_i 's SVID key
 - 5: **return** ADC' $\triangleright$ no authorization-server round trip (R3)
-

Algorithm 3: VERIFYANDAUTHORIZE. Per-action runtime check (gateway or PEP).

1: **input:** presented ADC $= [B_0, \dots, B_n]$, PoP proof p , requested action (s, v) , context ctx
2: resolve K_O for ρ via domain discovery; assert $\text{Verify}_{K_O}(B_0)$
3: **for** $i = 1..n$: assert $\text{Verify}_{pk_{i-1}}(B_i)$ and $B_i.\text{link} = H(B_{i-1})$ $\triangleright$ chain and attribution (R1, R2)
4: assert $\text{now} < \min_i \tau_i$ and PoP p matches π_n $\triangleright$ freshness and possession (R5)
5: assert discharge and revocation checks pass for all third-party caveats $\triangleright$ (R7)
6: $\sigma_{\text{eff}} \leftarrow \bigcap_{i=0}^n \sigma_i$ $\triangleright$ conjunction of caveats is monotone (Definition 5)
7: assert $(s, v) \in \llbracket \sigma_{\text{eff}} \rrbracket$ and $\text{PDP}(\rho, (s, v), ctx) = \text{allow}$ $\triangleright$ runtime PDP (R6)
8: **if** (s, v) is high-impact: require human-checkpoint token
9: append $\langle \rho, \text{attrib}(\text{ADC}), (s, v), \text{decision}, t \rangle$ to transparency log $\triangleright$ observability (R7)
10: **return** *allow*; inject on-behalf-of context so the target never sees a naked machine identity

Algorithm 4: REVOKE. Cut a link (any principal in the chain).

1: **input:** block hash $H(B_j)$ or root ρ to revoke
2: publish $H(B_j)$ (or ρ) to the revocation registry with timestamp
3: discharge service refuses future “not-revoked” proofs for any chain containing $H(B_j)$
4: **effect:** every capability whose chain includes B_j fails VERIFYANDAUTHORIZE

5 Reference Architecture

The construction is enforced by seven cooperating components (Figure 1), extending the four-tier Organization, User, Agent, Capability identity model of the companion Agentic Authority Architecture [1] with the concrete cryptographic spine above.

1. **Delegation Authority (DA).** A capability service that authenticates the human, computes the intersection ceiling, and mints root ADCs (Algorithm 1). It is the only component that needs the human’s ceiling; downstream hops are offline.
2. **Workload Identity Plane.** SPIFFE and SPIRE issue each agent an attested SVID and key pair [12], so “who is this agent” is answered by attestation rather than a shared service account, which is the precondition for attribution.
3. **Identity-Aware Gateway (PEP).** A sidecar or proxy at every cross-agent and cross-tool boundary. It runs VERIFYANDAUTHORIZE (Algorithm 3), resolves the effective scope, calls the PDP, injects on-behalf-of context, and is the single enforcement point where trust is established.
4. **Policy Decision Point (PDP).** A runtime policy engine (Open Policy Agent with Rego [13]) evaluating each action against the resolved capability and originating principal (R6).
5. **Transparency Log.** An append-only Merkle log (Certificate-Transparency style [14]) recording each handoff and decision keyed to the chain root, giving tamper-evident, end-to-end auditability (R7).
6. **Revocation Registry and Discharge Service.** Serves short-lived “not-revoked” discharges for third-party caveats and publishes revoked block hashes.

7. **Human-Checkpoint Service.** Provides step-up authorization tokens gating irreversible or high-impact actions (transact, delete, deploy, cross an organizational boundary), the backstop when automated reasoning about scope is uncertain.

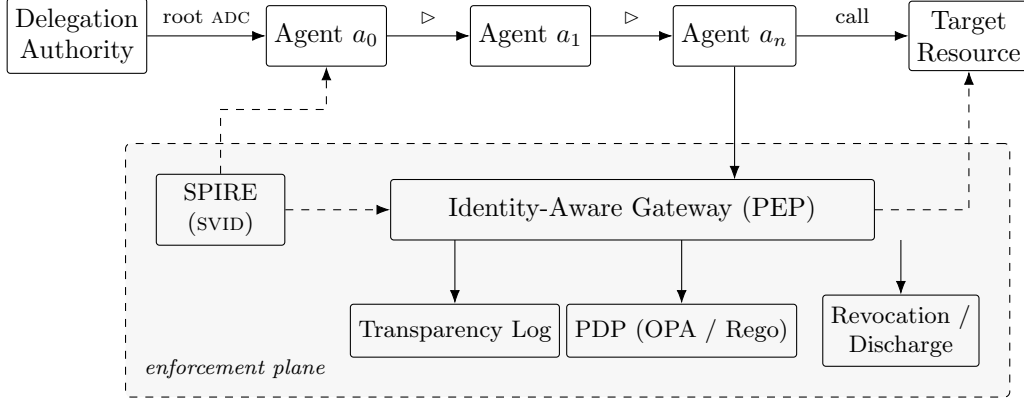


Figure 1: Reference architecture. A root ADC minted against the intersection ceiling is attenuated offline at each hop ($\triangleright$). At the target boundary the identity-aware gateway verifies the chain, evaluates the action at the PDP, checks revocation, and writes a tamper-evident record before injecting on-behalf-of context.

5.1 Mapping to existing standards

The architecture is deployable today by composition rather than by a new wire protocol. Table 1 maps each requirement to its mechanism and the standard that realizes it.

Requirement	adc mechanism	Realized by
R1 Verifiable chain	Hash-chained signed blocks	biscuit, macaroons [4, 3]
R2 Attribution	Per-hop SVID signatures plus root reference	SPIFFE [12]; Algorithm 3
R3 Holder-side attenuation	Offline caveat append	macaroons [3]; Algorithm 2
R4 Intersection ceiling	$\sigma_0 = \sigma_r \sqcap \text{pol} \sqcap \text{ceil}(h)$ plus monotonicity	DA MINT [7]
R5 Freshness	Short TTL plus PoP binding	DPoP [8]; Txn-Tokens [10, 11]
R6 Runtime authorization	Per-action PDP at gateway	OPA and Rego [13]
R7 Revocation and audit	Third-party caveats plus Merkle log	CT [14]

Table 1: Each session-trust requirement (Section 2) mapped to an ADC mechanism and the deployable standard that realizes it. GNAP [9] may replace the DA’s grant negotiation.

6 Security Analysis

Theorem 1 (Monotone attenuation). *For any well-formed chain $\Gamma = (c_0, \dots, c_n)$ produced by Algorithms 1 and 2, $\text{scope}(c_n) \subseteq \dots \subseteq \text{scope}(c_0)$.*

Proof. DELEGATE forms c_{i+1} by appending caveats δ_i , and VERIFYANDAUTHORIZE computes $\sigma_i = \bigcap_{k \leq i} \delta_k$ as a conjunction of caveats. Since adding a caveat can only shrink the denoted action set, $\llbracket \sigma_{i+1} \rrbracket = \llbracket \sigma_i \sqcap \delta_i \rrbracket = \llbracket \sigma_i \rrbracket \cap \llbracket \delta_i \rrbracket \subseteq \llbracket \sigma_i \rrbracket$. A block cannot remove a predecessor's caveat without breaking the hash-chain link $H(B_i)$ checked in Algorithm 3, line 3, which by collision-resistance of H is infeasible. Induction over i gives the claim. $\square$

Theorem 2 (Intersection-ceiling safety). *Every chain accepted by Algorithm 3 satisfies $\text{eff}(\Gamma) \subseteq \text{ceil}(h)$ for its originating human h . Consequently the confused-deputy condition (1) never authorizes an action: if $(h, (s, v)) \notin R_h$ then no accepted chain rooted at h authorizes (s, v) .*

Proof. By MINT (line 3), $\text{scope}(c_0) = \sigma_r \sqcap \text{pol}(a_0) \sqcap \text{ceil}(h) \subseteq \text{ceil}(h)$. By Theorem 1, $\text{eff}(\Gamma) = \text{scope}(c_n) \subseteq \text{scope}(c_0) \subseteq \text{ceil}(h)$. The root block commits to $H(\text{ceil}(h))$ and is signed by K_O ; altering the committed ceiling breaks the signature (EUF-CMA). Algorithm 3 accepts (s, v) only if $(s, v) \in \llbracket \text{eff}(\Gamma) \rrbracket$, hence $(s, v) \in \llbracket \text{ceil}(h) \rrbracket$, that is $(h, (s, v)) \in R_h$. The contrapositive is exactly the exclusion of (1): an agent's own broader pol can never lift effective authority above the human's ceiling. $\square$

Theorem 3 (Attribution soundness). *Under EUF-CMA signatures and collision-resistant H , the ADC construction is attribution-sound (Definition 7): any accepted chain uniquely and unforgeably determines the originating human and the ordered delegating agents at every hop, across domains and without pre-arranged federation.*

Proof. An accepted chain fixes B_0 signed by K_O (naming h and O) and each B_i signed by pk_{i-1} and linked by $H(B_{i-1})$ (Algorithm 3, lines 2 and 3). The ordered signer list $(K_O, pk_0, \dots, pk_{n-1})$, each an attested SVID, is therefore the attribution. Suppose a PPT adversary outputs an accepted chain whose attribution differs from the actual signers. Then either (i) some accepted B_i verifies under a pk_{i-1} that its holder never signed, which is an EUF-CMA forgery, or (ii) two distinct predecessor blocks share a link value $H(B_{i-1})$, which is an H -collision. Both occur with negligible probability, so attribution differs from the true signers only negligibly often. Cross-domain verification uses discoverable roots (no federation), so the argument is domain-independent. $\square$

Theorem 4 (Bounded delegation depth). *No accepted chain exceeds the root depth budget: $n \leq d_{\max}$.*

Proof. MINT sets $\text{depth}(B_0) = d_{\max}$ and DELEGATE decrements depth by one per hop, refusing when depth would reach 0 (line 2). Depth is inside each signed block, so a forged increment is an EUF-CMA forgery. Thus a well-formed accepted chain has at most $d_{\max}$ attenuation steps. $\square$

Theorem 5 (Contagion containment). *If an adversary compromises the holder of c_i , the authority it can wield or pass on is at most $\text{scope}(c_i)$, and it cannot re-widen toward $\text{scope}(c_0)$ or toward pol of any other agent.*

Proof. The compromised holder possesses c_i and a_i 's key. Any capability it mints is $c_i \triangleright (\cdot)$, which by Theorem 1 has $\text{scope} \subseteq \text{scope}(c_i)$; by Theorem 2 still $\subseteq \text{ceil}(h)$; and by Theorem 4 of strictly smaller depth. It cannot forge a block signed by an uncompromised predecessor's key (EUF-CMA), so it cannot fabricate a higher-authority ancestor. Hence blast radius is

bounded by the already-attenuated $\text{scope}(c_i)$ rather than the union of credentials on the path, which is the property token-forwarding lacks. $\square$

6.1 Attack scenarios

We map the four adversary behaviors of Section 2 to the mechanism that defeats each.

(a) Injection-driven confused deputy. A payload in retrieved content induces a benign agent to invoke a high-impact tool. The gateway resolves $\text{eff}(\Gamma)$; by Theorem 2 the action is authorized only if it lies within the originating human’s ceiling. An injected request to exceed that ceiling is rejected at runtime regardless of the agent’s own policy grant. (Note: this bounds authority; detecting the injection itself is defense-in-depth, Section 9.)

(b) Authority re-delegation contagion. A compromised agent tries to re-inject its authority one hop further. By Theorems 4 and 5 the forwarded capability is strictly weaker and depth-bounded; it cannot regain the root’s scope, so a local compromise cannot silently become a system-wide one.

(c) Cross-organization token pivot. As in the Salesloft and Drift pattern, an attacker reuses trust from one relationship to reach another. Because each ADC is bound by root reference, audience caveats and PoP to a specific originating human and target context, a captured chain verifies only for its own bounded scope and cannot be pivoted to a different target or principal (Theorem 3, R5).

(d) Identity collapse. Running under a shared credential is impossible by construction: the gateway rejects any presentation lacking a valid per-agent SVID signature chain, and injects on-behalf-of context so the target never sees a naked machine identity, restoring the human anchor the on-behalf-of pattern requires.

7 Prototype and Evaluation

7.1 Prototype composition

We describe a prototype that instantiates the architecture from existing components: agent identities via **SPIRE** (SVID issuance and attestation); ADC blocks via a **biscuit-style public-key token library** (Datalog caveats, offline attenuation); the gateway as an **Envoy ext_authz** sidecar invoking **Open Policy Agent** for the PDP; a **Merkle transparency log** (CT-style) for audit; and a discharge and revocation microservice. Root minting maps onto RFC 8693 Token Exchange or G NAP at the DA; cross-service context propagation aligns with Transaction Tokens, including the “for Agents” profile [7, 9, 10, 11].

7.2 Analytical cost model

Let n be chain length. ADC size is $O(n)$: each block adds a fixed-size header, its caveats, an SVID public-key reference, and one signature. Verification (Algorithm 3) is $O(n)$ signature checks plus $O(n)$ hash-link checks, followed by a single PDP evaluation whose cost is that of

the Rego query. Minting and delegation are $O(1)$ amortized (one signature each); delegation requires no network round trip, which is the primary latency advantage over central re-issuance at each hop.

7.3 Illustrative overhead budget

Table 2 gives an order-of-magnitude, illustrative budget derived from the cost model and public component benchmarks; it is a design target, not measured experimental data. Absolute numbers depend on signature scheme (for example Ed25519), policy complexity and deployment, and must be validated empirically before publication of results.

Cost component	Illustrative value	Basis
Per-block signature verify (Ed25519)	~ 0.05 to 0.15 ms	signature microbench (projected)
Chain verify, depth $n = 4$	~ 0.5 to 1.0 ms	$O(n)$ signature and hash checks
PDP decision (compiled Rego)	~ 0.1 to 1.0 ms	policy-engine typical range
Transparency-log append (async)	off critical path	batched Merkle insert
Added per-hop gateway latency	~ 1 to 3 ms	sum of above, excluding network
ADC size at depth $n = 4$	~ 1.2 to 2.0 KB	$O(n)$, few hundred B per block

Table 2: Illustrative, to-be-validated overhead budget from the analytical cost model and public component benchmarks, not measured results. Delegation adds no network round trip, and the transparency-log append is asynchronous and off the authorization critical path.

7.4 Requirement coverage

Table 3 compares single building blocks against the composed ADC architecture over the seven requirements. No single mechanism covers the set; the composition does.

	R1	R2	R3	R4	R5	R6	R7
OAuth 2.0 Token Exchange [7]	$\sim$	$\sim$	$\times$	$\sim$	$\checkmark$	$\times$	$\sim$
SPIFFE and SPIRE [12]	$\times$	$\checkmark$	$\times$	$\times$	$\checkmark$	$\times$	$\sim$
Macaroons [3]	$\checkmark$	$\times$	$\checkmark$	$\times$	$\checkmark$	$\times$	$\checkmark$
Transaction Tokens [10]	$\sim$	$\checkmark$	$\times$	$\sim$	$\checkmark$	$\sim$	$\times$
ADC architecture (this work)	$\checkmark$	$\checkmark$	$\checkmark$	$\checkmark$	$\checkmark$	$\checkmark$	$\checkmark$

Table 3: Requirement coverage. $\checkmark$ full, $\sim$ partial, $\times$ none. The composed architecture is the first to satisfy all seven simultaneously; the theorems of Section 6 justify the final row.

8 Related Work

Delegation and capability security. The confused deputy dates to Hardy [2]; capability systems and authoriZation-Based Access Control (ZBAC) argue for carrying authority with the request rather than inferring it from identity [6]. SPKI and SDSI established public-key, chain-based authorization [5]. Macaroons introduced efficient chained-HMAC caveats with first-party and third-party discharges [3]; biscuit modernizes this with public-key blocks

and Datalog [4]. ADC inherits monotone, offline attenuation from this line and adds a human-anchored intersection ceiling and SVID-bound attribution.

Agent and workload identity standards. OAuth Token Exchange conveys on-behalf-of delegation but offers no holder-side attenuation and drops the prior chain [7]; GNAP generalizes grant negotiation without prior client registration [9]; DPoP binds tokens to a key [8]; Transaction Tokens and the “for Agents” profile propagate authorization context through a call chain within a trust domain [10, 11]. SPIFFE and SPIRE attest workload identity [12]. These are the building blocks our architecture composes; individually none closes the requirement set (Table 3).

Agentic security. The companion analysis frames the handoff as the unit of risk and states the seven requirements [1]. Formalizations of the agentic confused deputy and mandatory-access-control defenses [18], the AIP proposal for verifiable delegation across MCP and A2A [17], OpenID’s agentic-identity gaps [19], and the NIST NCCoE concept paper [20] converge on first-class identities, runtime authorization and traceable delegation. ADC contributes a construction with proofs for the attenuation and attribution properties those efforts identify as missing.

9 Limitations and Future Work

ADC bounds authority, not intent: it prevents an injected instruction from exceeding the human ceiling, but does not by itself detect that an injection occurred; distinguishing a legitimate handoff from an injection-provoked one at the boundary remains open [1]. Caveat expressiveness trades against decidable, low-latency runtime checking, so identifying policy languages that are both expressive and tractable under attenuation is future work. Revocation is only as timely as discharge TTLs and registry propagation. The honest-gateway assumption concentrates enforcement in the PEP; hardware attestation of the PEP and n-of-m logging would relax it. Finally, cross-domain verification presumes discoverable, trustworthy organizational roots, and bootstrapping that discovery layer (verifiable credentials for organizational roots) is a deployment prerequisite. Empirical validation of Table 2 on public multi-agent benchmarks [18] is the immediate next step, alongside standardizing the ADC block format across MCP, A2A and OAuth domains.

10 Conclusion

The agent-to-agent handoff fails for a structural reason: an authorization stack built for one human, consenting once, delegating one hop, cannot say whose authority is being spent by the fourth hop of a recursive, cross-domain chain. This paper closes that gap with a construction rather than a warning. The Attenuated Delegation Credential makes scope monotone, binds every hop to an attested identity, anchors the whole chain to an originating human’s intersection ceiling, and remains verifiable across domains without pre-arranged federation, and the surrounding reference architecture enforces it per action, at runtime, with a tamper-evident trail. We proved monotone attenuation, intersection-ceiling safety, attribution soundness, bounded depth and contagion containment, and showed the composition blocks

four attack classes that no single existing block prevents. When software becomes staff, it needs an identity, a manager and a paper trail. The ADC is a way to give the handoff all three.

References

- [1] B. Kumar. *The Agent-to-Agent Handoff Problem: Session Trust and Privilege Escalation Across Agent Boundaries*. Preprint, cs.CR, March 2026.
- [2] N. Hardy. *The Confused Deputy (or why capabilities might have been invented)*. ACM SIGOPS Operating Systems Review, 22(4):36-38, 1988.
- [3] A. Birgisson, J. G. Politz, Ú. Erlingsson, A. Taly, M. Vrabie and M. Lenczner. *Macaroons: Cookies with Contextual Caveats for Decentralized Authorization in the Cloud*. NDSS, 2014.
- [4] G. Fernandez et al. *Biscuit: a bearer token with offline attenuation and public-key verification (biscuit-auth specification)*. 2021 to present. <https://www.biscuitsec.org/>.
- [5] C. Ellison, B. Frantz, B. Lampson, R. Rivest, B. Thomas and T. Ylonen. *SPKI Certificate Theory*. RFC 2693, IETF, 1999.
- [6] A. H. Karp, H. Haury and M. H. Davis. *From ABAC to ZBAC: The Evolution of Access Control Models*. HP Laboratories Tech. Report HPL-2009-30, 2009.
- [7] M. Jones, A. Nadalin, B. Campbell, J. Bradley and C. Mortimore. *OAuth 2.0 Token Exchange*. RFC 8693, IETF, 2020.
- [8] D. Fett, B. Campbell, J. Bradley, T. Lodderstedt, M. Jones and D. Waite. *OAuth 2.0 Demonstrating Proof of Possession (DPoP)*. RFC 9449, IETF, 2023.
- [9] J. Richer (Ed.) and F. Imbault. *Grant Negotiation and Authorization Protocol (GNAP)*. RFC 9635, IETF, October 2024.
- [10] A. Tulshibagwale, G. Fletcher and P. Kasselmann. *Transaction Tokens*. Internet-Draft draft-ietf-oauth-transaction-tokens (OAuth WG), 2024 to 2026.
- [11] A. Tulshibagwale et al. *Transaction Tokens for Agents*. Internet-Draft draft-oauth-transaction-tokens-for-agents (OAuth WG), 2026.
- [12] SPIFFE and SPIRE Project (CNCF). *Secure Production Identity Framework for Everyone; SPIFFE Verifiable Identity Document (SVID)*. <https://spiffe.io/>.
- [13] Open Policy Agent Project (CNCF). *OPA and the Rego Policy Language*. <https://www.openpolicyagent.org/>.
- [14] B. Laurie, A. Langley and E. Kasper. *Certificate Transparency*. RFC 6962, IETF, 2013.
- [15] Anthropic. *Model Context Protocol (MCP) Specification*. 2024 to present. <https://modelcontextprotocol.io/>.
- [16] Google. *Agent-to-Agent (A2A) Protocol Specification*. 2025.
- [17] AIP: *Agent Identity Protocol for Verifiable Delegation Across MCP and A2A*. Preprint, cs.CR, 2026.
- [18] *Taming Privilege Escalation in LLM-Based Agent Systems: A Mandatory Access Control Framework; and A Framework for Formalizing LLM Agent Security*. Preprints, cs.CR, 2026.
- [19] OpenID Foundation. *Identity Management for Agentic AI*. October 2025.
- [20] NIST National Cybersecurity Center of Excellence. *Accelerating the Adoption of Software and AI Agent Identity and Authorization*. Concept paper, February 2026. See also NIST AI Risk Management Framework 1.0, 2023.